

Security Risk Assessment

Segmented Network Security SIEM

Accessor: Jon * Date: September 2026 * Classification: Lab / Portfolio

<https://github.com/JWT890/segmented-network-security-siem-lab>

Review Cadence: Post-Attack Simulation Review

1. Scope & Methodology

This risk assessment covers the virtual lab environment documented in the SIEM project. The assessment is based on the findings from active vulnerability scanning, attack simulation, alert analysis, and manual review of network configuration and firewall rules. It doesn't cover the host machine or external networks. The environment is built in VirtualBox and comprises the pfSense firewall with 5 isolated VLANs, Wazuh SIEM, Sysmon for Linux, Suricata, ntopng, and pfBlockerNG.

Risk Formula

Risk Scores are calculated using the formula: Risk Score = Likelihood * Impact

Each factor is assigned a numeric value based on its qualitative rating. The product of these two values produces a risk score that maps to a final risk level:

Rating	Likelihood Value	Impact Value	Score Band -> Risk Level
Critical / High	3	4	9 -12 -> Critical
High / High	3	3	6 - 8 -> High
Medium	2	2	3 - 5 -> Medium
Low	1	1	1 - 2 -> Low
None / Info	0	0	0 -> Info

So for example: A threat with level of High likelihood (3) and High Impact (3) produces a score of 9, which means is Critical. A threat with a low likelihood (1) and a High impact (3) produces a score of 3, which means is Medium

Risk Rating Legend

Risk Level	Score	Definition
Critical	9 - 12	Immediate action required. High likelihood of exploitation with severe impact.
High	6 - 8	Address within 30 days. Significant risk that could lead to compromise or data loss
Medium	3 - 5	Address within 90 days. Moderate risk with limited impact or low likelihood
Low	1 - 2	Address when resources permit. Minimal risk with negligible impact
Info	0	No risk identified. Noted for completeness only.

Risk Matrix

Risk ratings are calculated using a qualitative matrix of Likelihood * Impact:

	Low Impact	Medium Impact	High Impact	Critical Impact
High Likelihood (3)	2 -> Low	3 -> Medium	6 -> High	9 -> Critical
Med Likelihood (2)	1 -> Low	2 -> Low	4 -> Medium	6 -> High
Low Likelihood (1)	0 -> Info	1 -> Low	2 -> Low	3 -> Medium

2. Assets in Scope

Asset	IP / Location	Description	Criticality
pfSense Firewall	192.168.56.2 / 10.0.x.1	Network perimeter, VLAN routing, Suricata, ntopng, pfBlockerNG, OpenVPN gateway, NAT	Critical
Wazuh SIEM	10.0.10.10 / 192.168.56.119	Security monitoring, alert correlation, log aggregation, active response manager	Critical
Linux Switch VM	192.168.56.x	802.1Q VLAN trunk bridge, carries VLANs between pfSense and endpoints	High
endpoint-server	10.0.20.x / 192.168.56.121	Ubuntu target VM, Apache web server, SSH, Wazuh agent, Sysmon for Linux	High
Kali Linux	192.168.56.150	Attack platform, Nmap, Hydra, Metasploit, Nikto, Gobuster, Wireshark	N/A
VLAN 10 – MGMT	10.0.10.0/24	Admin access only: hosts Wazuh SIEM and firewall restricted	Critical
VLAN 20 – SERVERS	10.0.20.0/24	Target endpoint segment: outbound 80/443 only from SERVERS subnet	High
VLAN 30 – GUEST	10.0.30.0/24	Internet access only blocked from all RFC1918 destinations	Low
VLAN 40 – IOT	10.0.40.0/24	Fully isolated: no inbound or outbound traffic permitted and no VMs deployed	Low
VLAN 50 – DMZ	10.0.50.0/24	Kali attack zone: permitted TCP to SERVERS on ports 22/80/443 and ICMP only	Medium

3. Risk Register

Risk scores are calculated using the Risk score formula. Each finding below includes the numeric score alongside the qualitative risk level

Number	Asset	Threat / Vulnerability	Likelihood	Impact	Score	Risk Level	Priority
1	Kali VM	Kali sits on vboxnet0 (192.168.56.x) alongside Wazuh and the endpoint VM. DMZ firewall rules (VLAN 50) are not enforced. Kali can directly reach MGMT plan without pfSense	High	High	9	Critical	Immediate
2	Wazuh SIEM – UFW disable	UFW is confirmed inactive. Ports 443 (dashboard) and UDP 514 (syslog) are reachable from any host on 192.168.56.0/24, including Kali. No authentication on syslog input	High	High	9	Critical	Immediate
3	OpenVPN – TLS auth / routing issues	Repeated TLS handshake failures documented. Exported .ovpn missing TLS static key in practice. Workaround of disabling Block private networks on WAN reduces inbound filtering	Medium	High	6	High	Short-term
4	pfSense – default credential below	Default credentials active during setup wizard. GUI reachable at 192.168.56.2 from any host-only adapter VM during window	Low	Critical	4	High	Short-term
5	MGMT VLAN: overly permissive rule	MGMT VLAN firewall rule allows unrestricted outbound traffic. Wazuh SIEM at 10.0.10.10. No explicit deny-all at the bottom of the ruleset	Medium	High	6	High	Short-term
6	Sysmon for Linux – minimal config	Config is custom rather than a hardened ruleset. Key event IDs likely missing process	Medium	Medium	4	Medium	Medium-term

		injection, DNS queries, network connections. Detection gaps in SIEM					
7	Attack sim bypasses pfSense	Most attack tools target 192.168.56.121 rather than 10.0.20.x. Attack bypasses pfSense VLAN rules and Suricata, network-level results are incomplete	High	Medium	6	Medium	Medium-term
8	PCAP committed to public repo	lab_attack_capture.pcap is public on GitHub. Exposes internal credentials of the SIEM	Low	Medium	2	Low	Low
9	VLAN 40 – IOT segment	Fully isolated segment with no VMs deployed and no inbound or outbound traffic permitted.	None	None	0	Info	No action

4. Risk Summary

Risk Level	Score Range	Count
Critical	9 -12	2
High	6 – 8	3
Medium	3 – 5	2
Low	1 – 2	1
Info	0	1
Total	-	9

The two most critical risks, Kali on the host-only network, (score 9) and Wazuh with ufw disabled (score 9), represent the most urgent items. Both are pretty straightforward to address and help harden the management and monitoring plane.

The 3 high risks score between 6 and 8: The OpenVPN TLS issue (6), the MGMT VLAN permissive rule (6), and the pfSense default credential window. All are **low**-effort fixes addressable within a short timeframe.

VLAN 40, IOT, is working as intended. Full isolation with no traffic permitted in either direction means no attack surface and no risk.

5. Recommendations

All recommendations are prioritized by risk level and include the expected score reduction following remediation.

Priority	Recommendation	Effort	Score	Risk Reduced
Immediate	Move Kali to VLAN 50, change Kali adapter 1 to the VLAN 50 interface so all attack traffic is enforced through pfSense DMZ rules	Low	9 -> 3	
Immediate	Enable ufw in Wazuh VM: allow 443 from admin host only, allow UDP 514 from pfSense LAN IP only, deny all else	Low	9 -> 2	
Short-term	Resolve OpenVPN TLS configuration: verify TLS static key in .ovpn export, re-enable Block private networks,	Medium	6 -> 2	

	document the working config			
Short term	Change pfSense admin password as the very first post-install action	Low	4 -> 0	
Short-term	Add an explicit deny-all at the bottom of the MGMT VLAN ruleset and restrict to admin host IPs only	Low	6 -> 1	
Medium-term	Replace minimal Sysmon config with a community hardened ruleset and ensure event IDs 3, 8, and 22 are captured	Low	6 -> 1	
Medium-term	Re-route attack sim traffic to VLAN IPs (10.0.20.x) through pfSense so all attacks tranverse the full monitoring stack	Low	6 -> 0	
Low	Add pcap file to gitignore and remove the pcap from the public repo history	Low	2 -> 0	

6. Top Three Priority actions

6.1 Move Kali to VLAN 50 DMZ (Immediate)

Risk Score: 9 (Critical) to 3 (Medium) after remediation

The most impactful single change is moving the Kali VM to the DMZ VLAN, making all firewall rules for the DMZ apply to the attack traffic. This makes sure Kali cannot directly reach Wazuh or the MGMT plane.

1. In the home of VirtualBox, go the Kali VM settings in Network and change Adapter 1 to the internal network interface used for VLAN 50 traffic.
2. Assign Kali a static IP in the 10.0.50.x range and set the gateway to 10.0.50.1 (pfSense DMZ interface).
3. Verify Kali can reach SERVERS (10.0.20.x) only on ports 22/80/443 based on the custom rule and for the DMZ.
4. Verify Kali cannot reach Wazuh VM on 10.0.10.10 / 192.168.56.119 or pfSense MGMT side by pinging.

6.2 Enable UFW on Wazuh VM (Immediate)

Risk Score: 9 (Critical) to 2 (Medium) after remediation

UFW is currently disabled on the Wazuh VM, leaving the dashboard (443) and syslog receiver (UDP 514) and open to the entire host only network including Kali.

1. SSH into the Wazuh VM and run: `sudo ufw default deny && sudo ufw default allow` outgoing.
2. Allow from dashboard host only: `sudo ufw allow` from 192.168.56.1 to any port 443
3. Allow syslog from pfSense LAN only: `sudo ufw allow` from 192.168.56.2 to any port 514 proto dup
4. Allow SSH from admin host: `sudo ufw allow` from 192.168.56.1 to any port 22
5. Enable: `sudo ufw enable && sudo ufw status verbose`
6. Verify syslog from pfSense still flows and the Wazuh dashboard is accessible

6.3 Resolve OpenVPN TLS Configuration (Short term)

Risk Score 6 (High) to 2 (Low) after remediation

The OpenVPN setup is documented repeated TLS failures and a routing workaround that reduced WAN security posture. The goal is a fully functional, authenticated VPN tunnel without disabling protective firewall rules

1. In pfSense under VPN -> OpenVPN -> Servers, open the Lab VPN server and copy the static key
2. Verify the key exists between <tls-auth> tags in the exported .ovpn file. If absent, paste in
3. Re-enable Block private networks on the WAN interface.
4. Confirm the Allow OpenVPN rule exists on WAN for UDP port 1194
5. Add a third adapter for the lab-wan NAT Network on the endpoint-server VM if not already present
6. Run `sudo openvpn --config /path/to/config.ovpn` and confirm "Initialization Sequence Completed"
7. Ping 10.0.20.1 through the tunnel to verify the SERVERS VLAN is reachable.

Conclusion

This risk assessment identified 9 risks across the lab environment using the Formula Risk Score = Likelihood * Impact. Results found 2 critical (score 9), 3 high (scores 4-6), 2 medium (4-6), 1 low (score 2), and 1 informational (score 0). All critical and high risks are remediable within a short timeframe at low to medium effort

The numeric scoring makes the relative security of each risk explicit. Both critical risks share the same score (9) but for different reasons: the Kali placement risk comes from the high likelihood meeting high impact, while the Wazuh UFW risk reflects the same combination against the asset considered the most important and sensitive, the SIEM. Addressing these two items first provides the highest score reduction per unit of effort.

The assessment demonstrates that the design intent of this lab is good: 5 isolated VLANs, a stateful firewall, layered IDS/IPS, **flow** monitoring, and a SIEM is a mature framework. The findings reflect implementation gaps rather than design failures: the attack platform bypasses the segmentation it was supposed to test through, and the monitoring platform is left exposed by a missing host firewall. Closing the gaps will also make future attack simulation data more representative, since all traffic will traverse the full detection attack.

All recommendations in this assessment are prioritized for implementation as part of the ongoing lab development documented at github.com/JWT890/segmented-network-security-siem-lab.